CSA6303- Threat Intelligence and Network Security

AT1: Application-Based Questions

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats |Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan

Total: 50

Student Name :B.Hari Sai **Register number:192311098**

Code of Conduct:

I B.Hari Sai/192311098 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

B.Hari Sai

AT1: Application-Based Questions

Q1.CIA Triad — Scenario Identification (5 marks)
An e-commerce site stays fully online during an incident, but customers notice product prices have been silently changed by an attacker who gained database write access. No downtime occurred. Which CIA Triad principle(s) are violated? Justify your answer

Answer:
Integrity is the primary principle violated.
The CIA Triad consists of three fundamental security principles:
- Confidentiality: Ensures that information is accessible only to authorized users.
- Integrity: Ensures that information remains accurate, complete, and unaltered by unauthorized users.
- Availability: Ensures that systems and information remain accessible when required.
Justification:
In this scenario, an attacker gains database write access and silently changes product prices on the e-commerce website.
- Integrity is violated because product prices are modified without authorization.
- Confidentiality may also be violated if the attacker accessed or viewed restricted database information, but this is not explicitly stated.
- Availability is not violated because the website remains fully online without downtime.
Conclusion: The primary violation is Integrity, because the attacker has altered data without authorization while the service remains available.

Q2. Risk Quantification — Annualized Loss Expectancy (10 marks)
A company's customer database is valued at $50,000. A breach would destroy/corrupt 40% of its value (Exposure Factor). Historical data shows this type of breach occurs about twice a year (Annualized Rate of Occurrence = 2). Calculate the Single Loss Expectancy (SLE) and the Annualized Loss Expectancy (ALE). Show all formulas used.

Answer:
Given:
- Asset Value (AV) = $50,000
- Exposure Factor (EF) = 40% = 0.40
- Annualized Rate of Occurrence (ARO) = 2
Step 1: Calculate Single Loss Expectancy (SLE)
Single Loss Expectancy represents the estimated financial loss from a single incident.
[SLE = AV/\times EF]

Substituting the values:

[SLE = 50,000 /times 0.40]
[boxed{SLE = $20,000}]

Therefore, the company is expected to lose $20,000 per breach.
Step 2: Calculate Annualized Loss Expectancy (ALE)
Annualized Loss Expectancy represents the estimated total loss per year due to a particular risk.
Formula:
[ALE = SLE /times ARO]

Substituting the values:
[ALE = 20,000 \times 2]

[boxed{ALE = \$40,000}]

- Single Loss Expectancy (SLE) = $20,000
- Annualized Loss Expectancy (ALE) = $40,000 per year
- Conclusion: The company should anticipate an estimated annual loss of $40,000 from this type of breach, assuming the historical occurrence rate and loss estimates remain representative.

Q3. Brute-Force Attack Time Estimation (10 marks)
An 8-character password uses a 62-character set (a-z, A-Z, 0-9). An attacker's cracking rig tests 1 billion passwords per second. Calculate the size of the keyspace and the worst-case time required to exhaust it. Express your answer in hours.

Answer:

Given:
- Password length = 8 characters
- Character set size = 62
- Cracking speed = 1 billion passwords per second = (10^9)
Step 1: Calculate the keyspace
The keyspace is the total number of possible passwords.
Formula:
[K = N^L]

Where:
- (N) = Number of possible characters = 62
- (L) = Password length = 8
Substituting:
[K = 62^8]
[boxed{K = 218,340,105,584,896}]

Therefore, the keyspace contains approximately \(2.1834 \times 10^{14}\) possible passwords.
Step 2: Calculate the worst-case cracking time
Formula:
[T = \frac{\text{Total keyspace}}{\text{Passwords tested per second}}]

[T = \frac{218,340,105,584,896}{1,000,000,000}]

[T = 218,340.1056 \text{ seconds}]

Step 3: Convert seconds into hours
Since 1 hour = 3,600 seconds:
[T_{\text{hours}} = \frac{218,340.1056}{3,600}]

[boxed{T_{\text{hours}} \approx 60.65 \text{ hours}}]

Final Answer:
- Keyspace = 218,340,105,584,896 passwords
- Worst-case time = 60.65 hours, or approximately 2.53 days.
Conclusion: At a constant rate of one billion guesses per second, an exhaustive brute-force attack would take approximately 60.65 hours in the worst case. This estimate assumes every

candidate can be tested at the stated rate; real-world password hashing and account protections can change the result substantially.

Q4. Risk Prioritization Matrix (10 marks)
Given five threats rated on Likelihood (1-5) and Impact (1-5), compute the Risk Score (Likelihood x Impact) for each and rank them in order of patching/budget priority:
(a) Ransomware — L4, I5;
(b) Phishing — L5, I3;
(c) Insider data theft — L2, I5;
(d) DDoS — L3, I3;
(e) Unpatched server exploit — L4, I4.

Answer:

Formula:
[text{Risk Score} = \text{Likelihood} \times \text{Impact}]

A higher risk score indicates greater priority for mitigation, subject to other factors such as business criticality and exploitability.

Step 1: Calculate the risk scores

Threat	Likelihood (L)	Impact (I)	Risk Score
(a) Ransomware	4	5	\(4 \times 5 = 20\)
(b) Phishing	5	3	\(5 \times 3 = 15\)
(c) Insider data theft	2	5	\(2 \times 5 = 10\)
(d) DDoS	3	3	\(3 \times 3 = 9\)
(e) Unpatched server exploit	4	4	\(4 \times 4 = 16\)

Step 2: Rank the threats by priority

Rank	Threat	Risk Score	Priority
1	Ransomware	20	Very High
2	Unpatched server exploit	16	High
3	Phishing	15	High
4	Insider data theft	10	Moderate
5	DDoS	9	Moderate

Step 3: Justification
1. Ransomware (20): Highest priority because it has high likelihood and very high impact. It can encrypt critical files and disrupt business operations.
2. Unpatched server exploit (16): Requires urgent attention because attackers may exploit known vulnerabilities to gain unauthorized access.
3. Phishing (15): Its high likelihood makes it a significant risk. Employee awareness and email filtering can reduce exposure.
4. Insider data theft (10): Although its likelihood is lower, the impact is severe. Access controls and audit logs are important.
5. DDoS (9): It can disrupt service availability, but its calculated score is the lowest among the five threats.
Conclusion: The order of patching and budget priority based strictly on the given risk scores is Ransomware → Unpatched server exploit → Phishing → Insider data theft → DDoS. In

practice, an actively exploited critical vulnerability may need immediate patching regardless of its numerical rank.

Q5. Passive vs. Active Threat Classification (5 marks)
Classify each of the following as a passive or active threat, and state which CIA principle it primarily threatens:
(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.
(b) An attacker performing ARP spoofing to redirect traffic.
(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Answer:

A passive threat attempts to obtain information without changing system resources or data.
An active threat attempts to modify, disrupt, or manipulate systems or communications.

Scenario	Threat Type	Primary CIA Principle	Justification
(a) Silently sniffing unencrypted traffic on public Wi-Fi	Passive	Confidentiality	The attacker observes network traffic to obtain sensitive information without altering it.
(b) ARP spoofing to redirect traffic	Active	Integrity	The attacker manipulates network address mappings and redirects traffic. Availability or confidentiality may also be affected.
(c) Long-term network reconnaissance without altering anything	Passive	Confidentiality	The actor gathers information about the network and its assets without modifying systems.

Conclusion: Scenarios (a) and (c) are passive threats, while scenario (b) is an active threat. Passive attacks primarily threaten confidentiality, whereas active attacks can threaten integrity and availability, depending on their purpose.

Q6. Threat Intelligence Lifecycle sequencing (10 marks)
A SOC analyst receives an executive request: "Are we at risk from the ransomware group currently targeting our industry?" Arrange the following into the correct order of the Threat Intelligence Lifecycle, and name each phase:
(i) Analysts correlate collected IOCs with internal logs.
(ii) A report is sent to the CISO.
(iii) The request itself is logged as a requirement.
(iv) OSINT and threat feeds are pulled for the group's known TTPs.
(v) The CISO's follow-up questions shape the next collection cycle.

Answer:

The Threat Intelligence Lifecycle is a structured process used to collect, analyze, and distribute intelligence that supports security decisions. It also incorporates feedback to improve future intelligence activities.
Correct sequence
1.Planning and Direction — (iii)

The executive's request is recorded as a requirement: determine whether the organization is at risk from the ransomware group targeting its industry.

2.Collection — (iv)
Analysts gather open-source intelligence (OSINT), threat feeds, indicators of compromise (IOCs), and information about the group's tactics, techniques, and procedures (TTPs).

3.Processing and Exploitation — preparation for analysis
Collected information is organized, normalized, and prepared for comparison. This step is implied in the scenario rather than separately listed.

4.Analysis and Production — (i)
Analysts correlate the collected IOCs with internal logs to identify possible indicators of compromise and assess the organization's exposure.

5.Dissemination — (ii)
The completed intelligence report is sent to the Chief Information Security Officer (CISO) to support decision-making.

6.Feedback — (v)
The CISO's follow-up questions refine the requirements and guide the next collection cycle.

Final answer for the given statements
The correct order is:
[boxed{(iii) \rightarrow (iv) \rightarrow (i) \rightarrow (ii) \rightarrow (v)}]

The full lifecycle includes the processing and exploitation phase between collection and analysis, even though it is not explicitly represented by a separate statement.
Conclusion: The lifecycle begins with defining the intelligence requirement, proceeds through collection and analysis, distributes the findings to the CISO, and uses feedback to improve the next cycle.